

CAPSTONE PROJECT · REPORT 3

Software Requirement Specification

FPTU Halloween Online — Hệ thống mua vé, quản lý sự kiện và check-in điện tử

Phiên bản 1.0 · Trạng thái: Baseline · Ngày: 26/07/2026

Mục lục

1. Kiểm soát tài liệu
2. Tổng quan sản phẩm
3. Yêu cầu người dùng và tác nhân
4. Use case
5. Yêu cầu chức năng
6. Yêu cầu dữ liệu và mô hình nghiệp vụ
7. Phân quyền và kiểm soát truy cập
8. Giao diện bên ngoài và API
9. Yêu cầu phi chức năng
10. Quy tắc nghiệp vụ và xử lý ngoại lệ
11. Tiêu chí nghiệm thu
12. Phạm vi chưa bao gồm và định hướng tương lai
13. Phụ lục: bảng mã yêu cầu

Phạm vi tài liệu: Tài liệu này mô tả yêu cầu sản phẩm, dữ liệu, API, bảo mật, vận hành và tiêu chí nghiệm thu. Theo yêu cầu, tài liệu không bao gồm sơ đồ screen flow.

1. Kiểm soát tài liệu

Trường	Giá trị
Tên sản phẩm	FPTU Halloween Online
Loại tài liệu	Software Requirement Specification (SRS)
Phiên bản	1.0 — Baseline
Ngôn ngữ	Tiếng Việt; tên API và trường dữ liệu giữ nguyên tiếng Anh
Cơ sở biên soạn	Report 3 — Software Requirement Specification và mã nguồn hiện tại của frontend/backend
Đối tượng sử dụng	Khách hàng, Product Owner, BA, UI/UX, frontend, backend, QA, DevOps và đội vận hành sự kiện

1.1. Lịch sử thay đổi

Phiên bản	Ngày	Loại	Mô tả	Người thực hiện
1.0	26/07/2026	A/M	Biên soạn SRS đầy đủ theo khung Report 3, bổ sung yêu cầu thực tế của hệ thống mua vé, thanh toán, QR, quản trị và chat.	Project team

Ký hiệu: A — Added; M — Modified; D — Deleted.

1.2. Quy ước yêu cầu

- **MUST:** bắt buộc để đáp ứng nghiệp vụ hoặc bảo mật.
- **SHOULD:** nên có; chỉ thay đổi khi Product Owner phê duyệt.
- **MAY:** tùy chọn, không phải điều kiện nghiệm thu cốt lõi.
- Mỗi yêu cầu có mã duy nhất, có thể truy vết sang test case và tiêu chí nghiệm thu.

2. Tổng quan sản phẩm

2.1. Mục đích

FPTU Halloween Online là nền tảng web hỗ trợ quảng bá sự kiện, bán vé điện tử, thanh toán trực tuyến, phát hành mã QR, kiểm soát khách vào cổng và quản lý hoạt động của đội ngũ tổ chức.

2.2. Vấn đề cần giải quyết

- Thay thế việc đăng ký, đối soát và kiểm tra vé thủ công.
- Cho phép người tham gia mua vé và nhận vé điện tử thuận tiện.
- Giảm nguy cơ dùng lại một vé hoặc check-in sai ngày.
- Cung cấp số liệu tập trung về vé, người dùng, đơn hàng, doanh thu và check-in.
- Tạo kênh trao đổi nội bộ giữa Staff và Admin.

2.3. Phạm vi sản phẩm

Nhóm	Trong phạm vi
Người tham gia	Đăng ký, đăng nhập, hồ sơ, danh sách vé, giỏ hàng, đặt hàng, thanh toán, xem vé, mã QR, liên hệ và nội dung sự kiện.
Vận hành sự kiện	Quét QR, kiểm tra thông tin khách, xác nhận check-in, xem vé và dashboard Staff.
Quản trị	Quản lý người dùng, loại vé, vé, đơn hàng, thống kê, liên hệ, tin nóng, chat và quyền Staff.
Tích hợp	PayOS cho thanh toán; email/OTP và Google OAuth nếu được cấu hình; camera trình duyệt cho quét QR; Socket.IO cho chat thời gian thực.

2.4. Bối cảnh hệ thống

Người tham gia → Website → Backend/API → MongoDB

Website cung cấp giao diện; backend xử lý xác thực, nghiệp vụ, thanh toán và dữ liệu; MongoDB lưu tài khoản, loại vé, vé, đơn hàng và chat. PayOS gửi kết quả thanh toán về backend qua webhook.

Staff/Admin → Khu vực điều hành → Backend/API

Nhân sự điều hành chỉ được gọi chức năng phù hợp với vai trò. Các thao tác quan trọng phải được kiểm tra lại ở backend, không chỉ dựa vào giao diện.

3. Yêu cầu người dùng và tác nhân

3.1. Tác nhân

Mã	Tác nhân	Mô tả	Mục tiêu
A01	Người tham gia	Người mua hoặc sử dụng vé tham dự sự kiện.	Mua vé, thanh toán, nhận vé và vào sự kiện.
A02	Staff	Nhân viên vận hành được Admin cấp quyền.	Kiểm tra vé, check-in khách và phối hợp vận hành.
A03	Admin	Người quản trị toàn bộ hệ thống.	Quản lý cấu hình, dữ liệu, nhân sự và theo dõi kết quả.
A04	PayOS	Dịch vụ thanh toán bên ngoài.	Tạo giao dịch, nhận thanh toán và gửi kết quả về hệ thống.
A05	Email/OTP provider	Dịch vụ gửi mã xác nhận và email hệ thống.	Xác nhận tài khoản, khôi phục mật khẩu và thông báo.
A06	Trình duyệt/camera	Thiết bị và trình duyệt người dùng.	Hiển thị web, lưu phiên đăng nhập và cung cấp camera quét QR.

3.2. Nhu cầu người dùng

Mã	Nhu cầu	Mức độ
UN-01	Người tham gia có thể mua vé mà không cần thao tác kỹ thuật phức tạp.	MUST
UN-02	Người tham gia biết rõ số tiền, ngày và thời gian của vé trước khi trả tiền.	MUST
UN-03	Nhân viên có thể kiểm tra vé nhanh và nhận biết vé sai ngày/đã dùng.	MUST
UN-04	Quản trị viên có thể xem số liệu và kiểm soát hoạt động tập trung.	MUST
UN-05	Đội ngũ có thể trao đổi nội bộ trong các cuộc trò chuyện cá nhân/nhóm.	SHOULD

4. Use case

4.1. Danh sách use case

Mã	Tên use case	Tác nhân chính	Kết quả
UC-01	Đăng ký tài khoản	Người tham gia	Tài khoản được tạo sau khi xác nhận.
UC-02	Đăng nhập và duy trì phiên	Người tham gia, Staff, Admin	Người dùng được truy cập đúng khu vực.
UC-03	Quản lý hồ sơ cá nhân	Người dùng đã đăng nhập	Thông tin hồ sơ được cập nhật.
UC-04	Xem và chọn loại vé	Người tham gia	Loại vé phù hợp được chọn.
UC-05	Quản lý giỏ hàng	Người tham gia	Danh sách và số lượng vé được điều chỉnh.
UC-06	Tạo đơn và thanh toán	Người tham gia, PayOS	Đơn được tạo, thanh toán và đối soát.
UC-07	Xem vé điện tử	Người tham gia	Vé và mã QR được hiển thị.
UC-08	Tra cứu vé bằng QR	Staff, Admin	Thông tin vé và khả năng check-in được trả về.
UC-09	Xác nhận check-in	Staff, Admin	Vé được đánh dấu đã sử dụng, ghi nhận người thực hiện.
UC-10	Quản lý loại vé	Admin	Loại vé được tạo, sửa hoặc tạm dừng.
UC-11	Quản lý người dùng và Staff	Admin	Tài khoản được xem, khóa/mở hoặc cấp vai trò.
UC-12	Quản lý đơn hàng và báo cáo	Admin	Doanh thu và số liệu được theo dõi.
UC-13	Trao đổi chat	Staff, Admin	Tin nhắn cá nhân/nhóm được gửi và nhận.
UC-14	Quản lý liên hệ và tin nóng	Người tham gia, Admin	Yêu cầu được tiếp nhận; nội dung được xuất bản.

4.2. Mẫu đặc tả use case

Các use case được mô tả chi tiết ở mục 5 dưới dạng yêu cầu chức năng. Mỗi yêu cầu bao gồm tác nhân, điều kiện, dữ liệu vào, xử lý chính, nhánh lỗi và kết quả đầu ra để QA có thể chuyển thành test case.

5. Yêu cầu chức năng

5.1. Xác thực và tài khoản

Mã	Yêu cầu	Quy tắc/ngoại lệ
FR-AUTH-01	Hệ thống MUST cho phép đăng ký bằng họ tên, email, số điện thoại và mật khẩu.	Email không hợp lệ, email đã tồn tại hoặc dữ liệu thiếu phải bị từ chối.
FR-AUTH-02	Hệ thống MUST gửi mã xác nhận khi quy trình đăng ký yêu cầu.	Mã hết hạn hoặc sai phải báo lỗi; không tiết lộ mã cho người khác.
FR-AUTH-03	Hệ thống MUST cho phép đăng nhập bằng thông tin hợp lệ và trả phiên truy cập an toàn.	Sai thông tin không được tiết lộ tài khoản nào tồn tại.
FR-AUTH-04	Hệ thống SHOULD hỗ trợ đăng nhập Google nếu cấu hình nhà cung cấp hợp lệ.	Không tạo tài khoản trùng email đã có nếu chính sách không cho phép.
FR-AUTH-05	Hệ thống MUST hỗ trợ quên và đổi mật khẩu.	Liên kết/mã đặt lại phải có thời hạn và chỉ dùng một lần.
FR-AUTH-06	Hệ thống MUST hỗ trợ làm mới và đăng xuất phiên.	Phiên hết hạn hoặc bị thu hồi phải yêu cầu đăng nhập lại.
FR-AUTH-07	Hệ thống MUST chặn tài khoản bị vô hiệu hóa.	Tài khoản bị khóa không được gọi chức năng cần đăng nhập.

5.2. Hồ sơ cá nhân

Mã	Yêu cầu
FR-PROFILE-01	Người dùng MUST xem được họ tên, email, số điện thoại và thông tin hồ sơ được phép hiển thị.
FR-PROFILE-02	Người dùng MUST cập nhật được thông tin cá nhân theo các trường được cho phép.
FR-PROFILE-03	Hệ thống MUST kiểm tra định dạng số điện thoại và dữ liệu bắt buộc trước khi lưu.
FR-PROFILE-04	Người dùng MUST chỉ xem được dữ liệu thuộc tài khoản của mình; Admin mới được xem dữ liệu quản trị theo quyền.

5.3. Danh sách và quản lý loại vé

Mã	Yêu cầu	Vai trò
FR-TYPE-01	Hệ thống MUST hiển thị tên, giá, ngày, thời gian, tổng số lượng, số lượng còn lại và tình trạng bán của loại vé.	Người dùng đã đăng nhập, Staff, Admin
FR-TYPE-02	Admin MUST tạo loại vé với tên, giá, số lượng, ngày và thời gian hợp lệ.	Admin
FR-TYPE-03	Admin MUST sửa thông tin loại vé theo chính sách dữ liệu đã phát hành.	Admin
FR-TYPE-04	Admin MUST bật/tắt tình trạng bán của loại vé.	Admin

FR-TYPE-05	Hệ thống MUST từ chối thêm vào giỏ hoặc mua loại vé không còn bán hoặc hết số lượng.	Hệ thống
------------	--	----------

5. Yêu cầu chức năng (tiếp)

5.4. Giỏ hàng

Mã	Yêu cầu
FR-CART-01	Người dùng MUST thêm loại vé đang bán vào giỏ hàng.
FR-CART-02	Người dùng MUST thay đổi số lượng hoặc xóa vé khỏi giỏ hàng.
FR-CART-03	Hệ thống MUST tính tổng tiền từ giá hiện tại và số lượng hợp lệ.
FR-CART-04	Hệ thống MUST kiểm tra lại loại vé và số lượng tại thời điểm tạo thanh toán, không tin tuyệt đối vào dữ liệu từ trình duyệt.

5.5. Tạo đơn và thanh toán

Mã	Yêu cầu	Tiêu chí xử lý
FR-PAY-01	Hệ thống MUST tạo Order chứa người mua, mặt hàng, số lượng, tổng tiền, phương thức và mã giao dịch duy nhất.	Không cho phép trùng mã giao dịch.
FR-PAY-02	Hệ thống MUST tạm giữ số lượng vé trước khi tạo link thanh toán.	Chỉ giữ được khi số lượng còn đủ; nếu không đủ phải trả lỗi thân thiện.
FR-PAY-03	Hệ thống MUST tạo giao dịch qua PayOS với tổng tiền và mặt hàng đã kiểm tra.	Không lấy số tiền từ client nếu chưa đối chiếu server.
FR-PAY-04	Hệ thống MUST cung cấp trang thanh toán và cho phép người dùng xem kết quả.	Không lộ secret key hoặc dữ liệu nhạy cảm.
FR-PAY-05	Hệ thống MUST nhận webhook và/hoặc chủ động kiểm tra kết quả thanh toán để cập nhật đơn.	Webhook phải xác thực; xử lý lặp lại không được phát hành vé trùng.
FR-PAY-06	Nếu thao tác lưu Order tạm thời lỗi sau khi tạo thanh toán, hệ thống MUST thử lại theo chính sách retry.	Nếu vẫn thất bại, phải có cơ chế đối soát/khôi phục để tránh khách trả tiền nhưng không có vé.
FR-PAY-07	Đơn chưa thanh toán hết thời gian MUST được chuyển sang không còn hiệu lực và số lượng được trả lại đúng một lần.	Thao tác hủy và hoàn số lượng phải chống xử lý đồng thời.
FR-PAY-08	Người dùng MUST xem và hủy giao dịch chưa hoàn tất nếu chính sách cho phép.	Không cho hủy đơn đã hoàn tất.

Yêu cầu quan trọng: Thanh toán thành công và phát hành vé là hai việc phải được đối soát. Hệ thống không được coi việc trình duyệt quay về trang kết quả là bằng chứng duy nhất của thanh toán.

5.6. Phát hành và xem vé

Mã	Yêu cầu
FR-TICKET-01	Sau khi thanh toán được xác nhận, hệ thống MUST tạo số vé tương ứng số lượng đã mua.

FR-TICKET-02	Mỗi vé MUST có mã riêng, loại vé, người sở hữu, đơn hàng, ngày và thời gian tham dự.
FR-TICKET-03	Mỗi vé MUST có mã QR riêng được sinh bởi server; định dạng nhận diện cụ thể không công khai trong tài liệu người dùng.
FR-TICKET-04	Người dùng MUST chỉ xem được vé thuộc tài khoản của mình.
FR-TICKET-05	Hệ thống MUST không tạo vé mới khi cùng một thanh toán được xử lý lại.

5. Yêu cầu chức năng (tiếp)

5.7. Tra cứu QR và check-in

Mã	Yêu cầu	Vai trò
FR-CHECK-01	Staff/Admin MUST quét hoặc nhập mã QR qua màn hình check-in.	Staff, Admin
FR-CHECK-02	Backend MUST kiểm tra mã QR hợp lệ, tồn tại và thuộc vé được phát hành.	Hệ thống
FR-CHECK-03	Màn hình MUST hiển thị đủ thông tin đối chiếu cần thiết: mã vé, tên, số điện thoại, loại vé, ngày và thời gian.	Staff, Admin
FR-CHECK-04	Hệ thống MUST chỉ cho phép check-in đúng ngày ghi trên vé.	Hệ thống
FR-CHECK-05	Vé đã check-in MUST không được check-in lại.	Hệ thống
FR-CHECK-06	Nút xác nhận MUST bị vô hiệu hóa nếu vé sai ngày, đã sử dụng, không hợp lệ hoặc thiếu điều kiện.	Frontend
FR-CHECK-07	Backend MUST tự kiểm tra lại mọi điều kiện khi nhận yêu cầu xác nhận.	Backend
FR-CHECK-08	Hệ thống MUST ghi nhận tài khoản nhân viên thực hiện, thời gian và vé được check-in.	Hệ thống
FR-CHECK-09	Hai yêu cầu check-in đồng thời cho cùng vé chỉ được phép có một yêu cầu thành công.	Hệ thống

5.8. Dashboard và báo cáo

Mã	Yêu cầu
FR-DASH-01	Admin MUST xem tổng số vé phát hành, số đã sử dụng, tỷ lệ sử dụng, tài khoản và doanh thu.
FR-DASH-02	Dashboard MUST có thể số liệu và biểu đồ cột, đường, tròn phù hợp với dữ liệu.
FR-DASH-03	Staff SHOULD xem số liệu phục vụ vận hành như lượt check-in và vé gần đây.
FR-DASH-04	Người dùng không được xem dashboard quản trị.
FR-DASH-05	Dữ liệu dashboard MUST hiển thị thời gian cập nhật hoặc trạng thái đang tải.

5.9. Quản trị người dùng, loại vé và đơn hàng

Mã	Yêu cầu
FR-ADMIN-01	Admin MUST xem danh sách người dùng có phân trang, tìm kiếm hoặc lọc phù hợp.
FR-ADMIN-02	Admin MUST vô hiệu hóa hoặc kích hoạt lại tài khoản theo quyền.
FR-ADMIN-03	Admin MUST cấp vai trò Staff cho tài khoản được phê duyệt.
FR-ADMIN-04	Admin MUST xem danh sách và chi tiết đơn hàng, vé và thông tin thanh toán được phép.
FR-ADMIN-05	Thao tác tạo/sửa/tạm dừng loại vé MUST được kiểm tra dữ liệu và ghi nhận thời gian cập nhật.

5. Yêu cầu chức năng (tiếp)

5.10. Chat nội bộ

Mã	Yêu cầu
FR-CHAT-01	Staff/Admin MUST xem các cuộc trò chuyện mà họ có quyền tham gia.
FR-CHAT-02	Người dùng nội bộ MUST tìm được thành viên hoặc nhóm theo thông tin được phép tìm kiếm.
FR-CHAT-03	Staff/Admin MUST gửi và xem tin nhắn cá nhân hoặc tin nhắn nhóm.
FR-CHAT-04	Danh sách nhóm MUST hiển thị người gửi tin nhắn gần nhất và nội dung xem trước khi có dữ liệu.
FR-CHAT-05	Khu vực tin nhắn MUST có thanh cuộn riêng, tự hiển thị tin mới nhất khi mở cuộc trò chuyện mà không làm cuộn toàn trang.
FR-CHAT-06	Admin MUST tạo nhóm, cập nhật nhóm và quản lý thành viên theo quyền.
FR-CHAT-07	Hệ thống MUST không tạo tin nhắn rỗng hoặc bản tin tạm trùng khi gửi tin.
FR-CHAT-08	Khi phiên hết hạn, giao diện MUST báo người dùng đăng nhập lại thay vì hiển thị lỗi khó hiểu.

5.11. Liên hệ, tin nóng và nội dung sự kiện

Mã	Yêu cầu
FR-CONT-01	Người tham gia MUST gửi được yêu cầu liên hệ với nội dung bắt buộc và thông tin phản hồi hợp lệ.
FR-CONT-02	Admin MUST xem, đọc, cập nhật trạng thái và xóa liên hệ theo quyền.
FR-NEWS-01	Admin MUST tạo, sửa, bật/tắt và xem danh sách tin nóng.
FR-NEWS-02	Khách truy cập chỉ được xem tin nóng đang được phép hiển thị.
FR-PUBLIC-01	Website MUST hiển thị thông tin sự kiện, giới thiệu, câu hỏi thường gặp, chính sách và điều khoản.

6. Yêu cầu dữ liệu và mô hình nghiệp vụ

6.1. Thực thể chính

Thực thể	Thông tin chính	Quan hệ
User	Họ tên, email, số điện thoại, mật khẩu đã mã hóa, vai trò, trạng thái.	Có nhiều Cart, Order, UserTicket, ChatConversation.
Role	Tên vai trò và thông tin quyền.	User tham chiếu Role.
TicketType	Tên, giá, tổng số lượng, số lượng còn lại, ngày, thời gian, tình trạng bán.	Có nhiều CartItem/OrderItem/UserTicket.
Cart	Người dùng và danh sách loại vé/số lượng.	Mỗi người dùng có giỏ hàng hiện hành.
Order	Người mua, mặt hàng, tổng tiền, mã thanh toán, phương thức, tình trạng, thời hạn giữ.	Liên kết User, UserTicket và TicketType qua items.
UserTicket	Chủ vé, đơn hàng, loại vé, mã QR, ngày tạo, tình trạng sử dụng.	Mỗi vé thuộc một Order.
StaffCheckin	Vé, nhân viên thực hiện, thời gian và kết quả.	Ghi nhận lịch sử check-in.
ChatConversation	Loại cuộc trò chuyện, tên nhóm, thành viên, trạng thái.	Có nhiều ChatMessage.
ChatMessage	Người gửi, cuộc trò chuyện, nội dung, thời gian.	Thuộc một ChatConversation.
Contact	Người gửi, nội dung, trạng thái xử lý, thời gian.	Được Admin xử lý.
HotNews	Tiêu đề, nội dung, trạng thái hiển thị, thời gian.	Được công khai khi đang hoạt động.
Otp/RefreshToken	Mã xác thực hoặc token đã bấm, thời hạn, trạng thái sử dụng/thu hồi.	Phục vụ xác thực và bảo mật phiên.

6.2. Yêu cầu toàn vẹn dữ liệu

- Mã email và mã giao dịch phải có quy tắc duy nhất phù hợp.
- Giá và số lượng phải là số hợp lệ, không âm; số lượng mua phải lớn hơn 0.
- Vé phải tham chiếu được người sở hữu, đơn hàng và loại vé còn tồn tại.
- Không xóa cứng dữ liệu đang được Order/UserTicket tham chiếu nếu làm mất lịch sử.
- Thông tin mật khẩu, mã OTP và token không được lưu hoặc trả về dưới dạng rõ.
- Các thao tác phát hành vé, check-in và hoàn số lượng phải có tính idempotent.

6. Yêu cầu dữ liệu và mô hình nghiệp vụ (tiếp)

6.3. Vòng đời đơn hàng

Giai đoạn	Điều kiện	Thao tác tiếp theo
Chờ thanh toán	Đơn đã tạo và vé đang được giữ.	Thanh toán, hủy hoặc hết thời gian.
Đang xử lý	Hệ thống đang xác nhận thanh toán/phát hành.	Hoàn tất phát hành hoặc xử lý lại khi có lỗi.
Đã thanh toán	Thanh toán đã được xác nhận.	Vé được hiển thị cho người mua.
Đã hủy	Thanh toán không hoàn tất hoặc giao dịch bị hủy.	Không phát hành vé; số lượng được trả lại một lần.

6.4. Vòng đời vé

Giai đoạn	Ý nghĩa	Điều kiện
Chưa sử dụng	Vé đã phát hành và có thể đưa ra cổng.	Đúng ngày và thông tin hợp lệ.
Đã sử dụng	Vé đã check-in thành công.	Không được check-in lại.
Không hợp lệ	Không tìm thấy, sai thông tin, sai ngày hoặc đã dùng.	Không được xác nhận.

6.5. Bảo toàn số lượng vé

Khi tạo thanh toán, hệ thống giảm số lượng còn lại để giữ vé. Nếu giao dịch không hoàn tất hoặc bị hủy, hệ thống trả lại đúng số lượng. Việc hủy đơn và trả số lượng phải được thực hiện nguyên tử theo từng đơn để tránh hoàn nhầm khi thanh toán xảy ra đồng thời.

7. Phân quyền và kiểm soát truy cập

Chức năng	Khách chưa đăng nhập	Người tham gia	Staff	Admin
Xem nội dung công khai	Được	Được	Được	Được
Đăng ký/đăng nhập	Được	Được	Được	Được
Hồ sơ cá nhân	Không	Của mình	Của mình	Của mình
Xem loại vé	Theo chính sách công khai	Được	Được	Được
Giỏ hàng/thanh toán	Không	Được	Theo chính sách	Theo chính sách
Vé của tôi	Không	Của mình	Của mình	Của mình
Danh sách vé vận hành	Không	Không	Được theo quyền	Được
Tra QR/check-in	Không	Không	Được	Được
Tạo/sửa loại vé	Không	Không	Không	Được
Quản lý người dùng/Staff	Không	Không	Không	Được
Đơn hàng và thống kê quản trị	Không	Không	Không	Được
Chat nội bộ	Không	Không	Được	Được
Tạo/quản lý nhóm chat	Không	Không	Theo quyền	Được

7.1. Nguyên tắc kiểm soát

- Backend MUST kiểm tra token, tài khoản còn hoạt động và vai trò ở mọi API cần bảo vệ.
- Frontend chỉ ẩn/hiện nút theo vai trò để hỗ trợ trải nghiệm; không được coi đó là biện pháp bảo mật.
- API chỉ trả các trường cần thiết cho từng màn hình; không trả mật khẩu, token, secret hoặc dữ liệu nội bộ.
- Người dùng chỉ được xem Order, Ticket và Cart thuộc tài khoản của mình.
- Thao tác nhạy cảm phải có giới hạn tần suất và ghi log đủ để điều tra.

8. Giao diện bên ngoài và API

8.1. Giao diện người dùng

- Website MUST chạy trên trình duyệt hiện đại trên máy tính và điện thoại.
- Giao diện MUST phản hồi theo kích thước màn hình; nội dung chat và bảng dữ liệu không được làm tràn toàn trang.
- Trạng thái đang tải, thành công và lỗi MUST được hiển thị rõ ràng bằng loading, skeleton hoặc thông báo/toast phù hợp.
- Thông báo lỗi cho người dùng phải dùng ngôn ngữ dễ hiểu, không đưa stack trace hoặc chi tiết máy chủ.
- Biểu mẫu phải có nhãn, thông báo lỗi tại trường và trạng thái nút không thể bấm khi dữ liệu chưa hợp lệ.

8.2. Nhóm API chính

Nhóm	Chức năng	Bảo vệ
Authentication	Đăng ký, OTP, đăng nhập, Google, đổi/quên mật khẩu, refresh, logout.	Các route phù hợp; secret chỉ ở server.
Users	Hồ sơ của mình; Admin xem và quản lý người dùng.	JWT + vai trò Admin cho dữ liệu quản trị.
Ticket Types	Xem loại vé; Admin tạo, sửa, xóa theo chính sách, thay đổi trạng thái.	Đọc có đăng nhập; ghi cần Admin.
Cart	Đọc, thêm, sửa, xóa mặt hàng trong giỏ.	JWT; chỉ của mình.
Payments	Tạo, kiểm tra, hủy thanh toán; webhook từ nhà cung cấp.	JWT cho người dùng; webhook xác thực riêng.
Tickets	Danh sách vận hành, vé của mình, tra QR, chi tiết và check-in.	JWT + Staff/Admin; giới hạn tần suất cho QR/check-in.
Orders/Statistics	Đơn của mình; Admin xem đơn, chi tiết và thống kê.	JWT; Admin cho dữ liệu quản trị.
Staff Chat	Tìm người, cuộc trò chuyện, tin nhắn, nhóm và thành viên.	JWT + Staff/Admin.
Contacts/Hot News	Gửi liên hệ; Admin xử lý; nội dung công khai.	Gửi công khai theo chính sách; quản lý cần Admin.

8.3. Giao tiếp và tích hợp

- API sử dụng JSON qua HTTPS trong môi trường triển khai thật.
- PayOS webhook phải được xác minh trước khi cập nhật đơn hoặc phát hành vé.
- Chat thời gian thực sử dụng kết nối socket; khi mất kết nối phải có trạng thái và cơ chế tải lại dữ liệu.
- Camera chỉ được sử dụng sau khi người dùng cấp quyền; hệ thống phải có cách nhập/đọc QR thay thế nếu camera không khả dụng.

9. Yêu cầu phi chức năng

9.1. Usability

Mã	Yêu cầu đo được
NFR-USE-01	Người dùng mới có thể hoàn tất mua vé sau tối đa 5 phút hướng dẫn thông thường.
NFR-USE-02	Thông báo phải nói rõ việc cần làm tiếp theo, không chỉ hiển thị mã lỗi.
NFR-USE-03	Nhân viên mới có thể thực hiện quét và xác nhận vé sau một buổi hướng dẫn ngắn.
NFR-USE-04	Các nút xác nhận hành động quan trọng phải có trạng thái disabled khi thao tác không hợp lệ.
NFR-USE-05	Trang phải dùng được ở chiều rộng màn hình điện thoại phổ biến và máy tính.

9.2. Performance

Mã	Yêu cầu
NFR-PERF-01	API đọc thông thường SHOULD trả kết quả trong 2 giây ở điều kiện mạng và tải bình thường.
NFR-PERF-02	API tra QR/check-in SHOULD trả kết quả trong 1 giây ở điều kiện bình thường, không tính thời gian camera.
NFR-PERF-03	Dashboard phải giới hạn dữ liệu, phân trang hoặc tổng hợp để tránh tải toàn bộ collection không cần thiết.
NFR-PERF-04	Chat phải giới hạn số tin nhắn tải mỗi lần và chỉ tải thêm khi người dùng cuộn.
NFR-PERF-05	Hệ thống phải giới hạn tần suất API nhạy cảm; ngưỡng cụ thể cấu hình theo môi trường.

9.3. Reliability and availability

Mã	Yêu cầu
NFR-REL-01	Không phát hành trùng vé khi webhook hoặc yêu cầu kiểm tra thanh toán được gọi nhiều lần.
NFR-REL-02	Không hoàn số lượng vé nhiều lần khi nhiều tiến trình cùng hết hạn một Order.
NFR-REL-03	Lỗi tạm thời khi lưu Order phải có retry và cơ chế đối soát giao dịch.
NFR-REL-04	Ứng dụng phải có endpoint health check và log lỗi ở backend.
NFR-REL-05	Thời gian khôi phục dịch vụ và chính sách sao lưu MongoDB phải được đội vận hành xác định trước khi phát hành thật.

9. Yêu cầu phi chức năng (tiếp)

9.4. Security

Mã	Yêu cầu
NFR-SEC-01	Mật khẩu MUST được băm trước khi lưu; không ghi password, OTP hoặc token rõ vào log.
NFR-SEC-02	Secret PayOS, JWT và email provider MUST chỉ nằm ở biến môi trường/server secret.
NFR-SEC-03	Tất cả API riêng tư MUST yêu cầu token hợp lệ và kiểm tra vai trò ở backend.
NFR-SEC-04	Webhook thanh toán MUST xác thực chữ ký hoặc cơ chế xác minh của nhà cung cấp.
NFR-SEC-05	API QR, check-in và thanh toán MUST có rate limit và phản hồi 429 thân thiện khi vượt ngưỡng.
NFR-SEC-06	Dữ liệu trả về MUST dùng nguyên tắc ít quyền nhất; không trả trường không cần thiết.
NFR-SEC-07	Truy vấn MUST dùng tham số an toàn; dữ liệu đầu vào phải được kiểm tra định dạng, độ dài và phạm vi.
NFR-SEC-08	Thông tin QR, mã giao dịch và dữ liệu khách không được công khai trong tài liệu hướng dẫn người dùng hoặc log không cần thiết.

9.5. Maintainability and deployment

Mã	Yêu cầu
NFR-MNT-01	Frontend và backend phải tách biệt; nghiệp vụ chính nằm ở service/backend, không tin logic chỉ ở UI.
NFR-MNT-02	API phải có response nhất quán và lỗi được dịch phù hợp ở frontend.
NFR-MNT-03	Thay đổi schema hoặc index phải có kế hoạch migration và kiểm tra dữ liệu trùng.
NFR-MNT-04	Build, lint và test phải chạy được trong môi trường CI trước khi triển khai.
NFR-MNT-05	Cấu hình triển khai Railway phải được ghi lại, bao gồm biến môi trường, domain, webhook và kết nối MongoDB.

10. Quy tắc nghiệp vụ và xử lý ngoại lệ

10.1. Quy tắc nghiệp vụ

Mã	Quy tắc
BR-01	Mỗi người chỉ được thao tác trên dữ liệu cá nhân của mình, trừ Admin theo quyền.
BR-02	Chỉ loại vé đang bán và còn số lượng mới được đưa vào giao dịch.
BR-03	Tổng tiền phải được tính lại tại backend từ giá và số lượng hợp lệ.
BR-04	Vé chỉ được phát hành sau khi thanh toán được xác nhận.
BR-05	Vé chỉ check-in vào đúng ngày được ghi trên vé.
BR-06	Vé đã check-in không được check-in lần hai.
BR-07	Mỗi lần check-in thành công phải gắn với một tài khoản Staff/Admin và thời điểm cụ thể.
BR-08	Không được phát hành nhiều bộ vé cho cùng một giao dịch thanh toán.
BR-09	Đơn hết thời gian phải hủy an toàn và trả số lượng đúng một lần.
BR-10	Thông tin nhạy cảm chỉ được hiển thị cho vai trò và màn hình cần thiết.

10.2. Ma trận lỗi và phản hồi

Tình huống	HTTP/hiển thị	Hành vi hệ thống
Dữ liệu nhập sai	Thông báo tại trường	Không gửi hoặc không lưu dữ liệu.
Chưa đăng nhập/hết phiên	Yêu cầu đăng nhập lại	Không trả dữ liệu riêng tư.
Không đủ vé	Thông báo hết hoặc không đủ vé	Không tạo giao dịch; không giữ thiếu số lượng.
Thanh toán thất bại/hết hạn	Thông báo dễ hiểu	Đơn không phát hành vé; xử lý trả số lượng an toàn.
Thanh toán thành công nhưng lưu lỗi	Không báo thành công giả	Retry, đối soát và khôi phục; chuyển sự việc cho Admin nếu cần.
QR không tồn tại	QR không hợp lệ	Không cho check-in.
QR sai ngày	Vé check-in sai ngày	Nút xác nhận bị khóa; không ghi nhận check-in.
QR đã dùng	Vé đã được sử dụng	Nút xác nhận bị khóa; không thay đổi lần hai.
Vượt rate limit	Thử lại sau	Từ chối tạm thời, không làm thay đổi dữ liệu.
Server/database lỗi	Thông báo hệ thống	Ghi log; không trả chi tiết kỹ thuật cho người dùng.

11. Tiêu chí nghiệm thu

11.1. Nhóm nghiệm thu người tham gia

- Đăng ký thành công với dữ liệu hợp lệ; dữ liệu sai bị báo rõ.
- Đăng nhập, đăng xuất, đổi/quên mật khẩu hoạt động đúng.
- Người dùng chỉ xem được hồ sơ, giỏ hàng, đơn hàng và vé của mình.
- Không thể mua loại vé đã tắt hoặc không đủ số lượng.
- Tổng tiền trên giao diện và backend khớp.
- Thanh toán thành công tạo đúng số vé và mã QR riêng.
- Webhook hoặc kiểm tra lặp lại không tạo vé trùng.
- Đơn hết hạn không làm mất hoặc nhân đôi số lượng vé.

11.2. Nhóm nghiệm thu Staff/Admin

- Staff/Admin tra cứu được QR hợp lệ và xem đúng thông tin cần đối chiếu.
- QR sai ngày, đã dùng hoặc không hợp lệ không thể xác nhận.
- Hai thao tác đồng thời chỉ có một check-in thành công.
- Hệ thống ghi nhận đúng người thực hiện và thời điểm check-in.
- Staff không truy cập được thao tác chỉ dành cho Admin.
- Admin quản lý được loại vé, người dùng, Staff, đơn hàng, liên hệ, tin nóng và chat.
- Dashboard hiển thị đúng số liệu sau khi làm mới.

11.3. Nhóm nghiệm thu phi chức năng

- Giao diện dùng được trên điện thoại và máy tính, không tràn toàn trang ở khu vực chat.
- Loading, thành công và lỗi được hiển thị rõ; không hiện lỗi kỹ thuật cho người dùng.
- API có xác thực, phân quyền, giới hạn tần suất và kiểm tra dữ liệu đầu vào.
- Log không chứa mật khẩu, token, OTP hoặc thông tin bí mật.
- Build/lint/test và quy trình triển khai được kiểm tra trước khi bàn giao.

12. Phạm vi chưa bao gồm và định hướng tương lai

12.1. Chưa bao gồm trong baseline

- Ứng dụng mobile native cho Android/iOS.
- Thanh toán ngoài nhà cung cấp đã tích hợp nếu chưa có cấu hình và phê duyệt.
- Hoàn tiền tự động và đối soát ngân hàng tự động hoàn toàn.
- In vé vật lý, thiết bị cổng chuyên dụng hoặc tích hợp turnstile.
- Phân quyền theo từng hành động nhỏ hơn vai trò hiện tại nếu chưa được thống nhất.
- Phân tích hành vi nâng cao, marketing automation và CRM đầy đủ.
- Sơ đồ screen flow, theo yêu cầu của chủ đầu tư.

12.2. Định hướng đề xuất

- Thêm job đối soát thanh toán định kỳ để xử lý trường hợp PayOS thành công nhưng server gặp lỗi khi lưu Order.
- Thêm audit log cho các thao tác Admin, thay đổi loại vé, hủy đơn và check-in.
- Dùng kho lưu trữ dùng chung cho rate limit khi triển khai nhiều server.
- Thêm test tự động cho race condition giữ/hoàn số lượng và check-in đồng thời.
- Bổ sung backup/restore và dashboard giám sát lỗi production.
- Thêm phân trang, tìm kiếm server-side và tổng hợp báo cáo theo thời gian.

13. Phụ lục: bảng mã yêu cầu

Tiền tố	Nhóm	Phạm vi
FR-AUTH	Authentication	Đăng ký, đăng nhập, phiên và mật khẩu.
FR-PROFILE	Profile	Thông tin cá nhân.
FR-TYPE	Ticket Type	Danh sách và quản lý loại vé.
FR-CART	Cart	Giỏ hàng.
FR-PAY	Payment	Đơn hàng, giữ số lượng, thanh toán, webhook.
FR-TICKET	Ticket	Phát hành và xem vé.
FR-CHECK	Check-in	Tra QR và xác nhận vào cổng.
FR-DASH	Dashboard	Thống kê và biểu đồ.
FR-ADMIN	Administration	Người dùng, Staff, loại vé và đơn hàng.
FR-CHAT	Chat	Cuộc trò chuyện cá nhân/nhóm.
FR-CONT/NEWS/PUBLIC	Content	Liên hệ, tin nóng và nội dung công khai.
NFR-*	Non-functional	Usability, performance, reliability, security, maintainability.
BR-*	Business Rules	Quy tắc nghiệp vụ dùng chung.

Kết luận: Baseline SRS này là nguồn tham chiếu để thiết kế, lập trình, kiểm thử, triển khai và nghiệm thu FPTU Halloween Online. Mọi thay đổi nghiệp vụ sau khi phê duyệt phải cập nhật mã yêu cầu và lịch sử thay đổi.